

MTSA CYBERSECURITY TRAINING FOR KEY PERSONNEL

For USCG-Regulated Facilities, Vessels, And OCS Facilities (As Required By 33 CFR 101 Subpart F)



MTSA CYBERSECURITY TRAINING FOR KEY PERSONNEL

*For USCG-Regulated Facilities, Vessels,
And OCS Facilities (As Required By 33
CFR 101 Subpart F)*

Today's training focuses on your role as Key Personnel under the new U.S. Coast Guard cybersecurity requirements.

We'll talk about what that means for you, what's expected during a cyber incident, and why staying current on cyber threats—especially with advances in AI—is becoming increasingly important in maritime operations.

Why You Are Receiving This Training

1. You work at or support a facility or vessel that is regulated under the Maritime Transportation Security Act (MTSA), which requires adherence to U.S. Coast Guard (USCG) security standards to protect people, operations, and the Marine Transportation System.
2. The USCG has introduced new cybersecurity requirements under 33 CFR 101 Subpart F. These regulations establish mandatory planning standards, reporting obligations, training requirements, and other cybersecurity measures for MTSA-regulated entities.
3. Because you work in a role that supports or interacts with Information Technology (IT) or Operational Technology (OT) systems, you must understand how your actions during day-to-day operations and during a cyber incident play a critical role in preventing, mitigating, and responding to cybersecurity risks that could impact safety, operational continuity, homeland security, and regulatory compliance.
4. You have been identified as "Key Personnel" who require additional training due to their elevated responsibilities, specialized access, or involvement in incident response and operational decision-making.



Proprietary and confidential. Not for distribution.

2

THE PASHA GROUP

You're receiving this training because you work at, or support, a facility or vessel regulated under the Maritime Transportation Security Act. The Coast Guard has added cybersecurity requirements under 33 CFR 101 Subpart F, and those rules apply directly to this operation.

Because of your role, whether that's working with IT or OT systems, having elevated system access, or making operational decisions, you're considered *Key Personnel*. That means you have a greater ability to either prevent a cyber incident or unintentionally make one worse. This training is about making sure it's the first one.

What 'Key Personnel' Means

- Individuals designated by the owner/operator based on their responsibilities and access, whose duties may include one or more of the following:
 - Direct involvement in cyber incident response and/or disaster recovery after a cyber incident
 - Cybersecurity responsibilities
 - Oversight for the operations of IT or remotely accessible OT systems
- Key Personnel must complete additional training addressing the following two topics:
 - *Roles and responsibilities during a cyber incident and response procedure*
 - *Maintaining current knowledge of changing cybersecurity threats and countermeasures*



Proprietary and confidential. Not for distribution.

3

THE PASHA GROUP

When we say 'Key Personnel,' we're not talking about job titles. We're talking about roles and responsibilities as defined by Coast Guard cybersecurity regulations and the organization's cybersecurity training program.

Key Personnel are individuals whose duties, access, or authority could affect the security, operation, or recovery of IT or OT systems. It may include supervisors, engineers, technicians, and others with elevated system access or assigned incident response responsibilities.

If your role gives you visibility into how systems operate, the ability to make or influence operational decisions, or responsibility for responding to abnormal conditions, you are considered Key Personnel. As a result, your actions before, during, and after a cyber incident can have a significant impact on safety, security, and regulatory compliance.

Why Your Role Matters

- You may be among the first to notice unusual or unsafe system behavior.
- Your timely actions can prevent, mitigate, or stop a cyber incident from escalating.
- You may have elevated access, system privileges, or a leadership role, meaning your decisions and actions could have a greater operational and security impact.
- You may support the Cybersecurity Officer (CySO) with incident reporting, evaluating system impacts, coordinating response actions, and communicating critical information.
- Cyber incidents can threaten personnel safety, security, physical equipment, and operational continuity, making your awareness essential.



Proprietary and confidential. Not for distribution.

4

THE PASHA GROUP

In many cyber incidents, the people who spot the first warning signs aren't cybersecurity experts. They're operators, engineers, or supervisors who notice something just doesn't look right.

Because you may be the first to see those signs, your actions can prevent an issue from escalating. And if you have elevated access or leadership authority, the decisions you make can have a much larger operational and safety impact. Cyber incidents don't just affect computers. They can affect people, equipment, and ongoing operations.

What Is a Cyber Incident?

- Any event that affects the confidentiality, integrity, or availability of IT or OT systems
- Examples include but are not limited to:
 - Unauthorized access to systems, applications, or data
 - Execution of malware or ransomware on organizational devices
 - Loss or theft of a device containing sensitive or regulated data
 - Phishing attacks resulting in credential compromise or user action
 - Distributed Denial-of-Service (DDoS) attacks that disrupt service availability
 - Insider misuse of system privileges or data access
 - Breach of physical security affecting IT or OT infrastructure
 - Detection of command-and-control (C2) traffic or exfiltration attempts



Proprietary and confidential. Not for distribution.

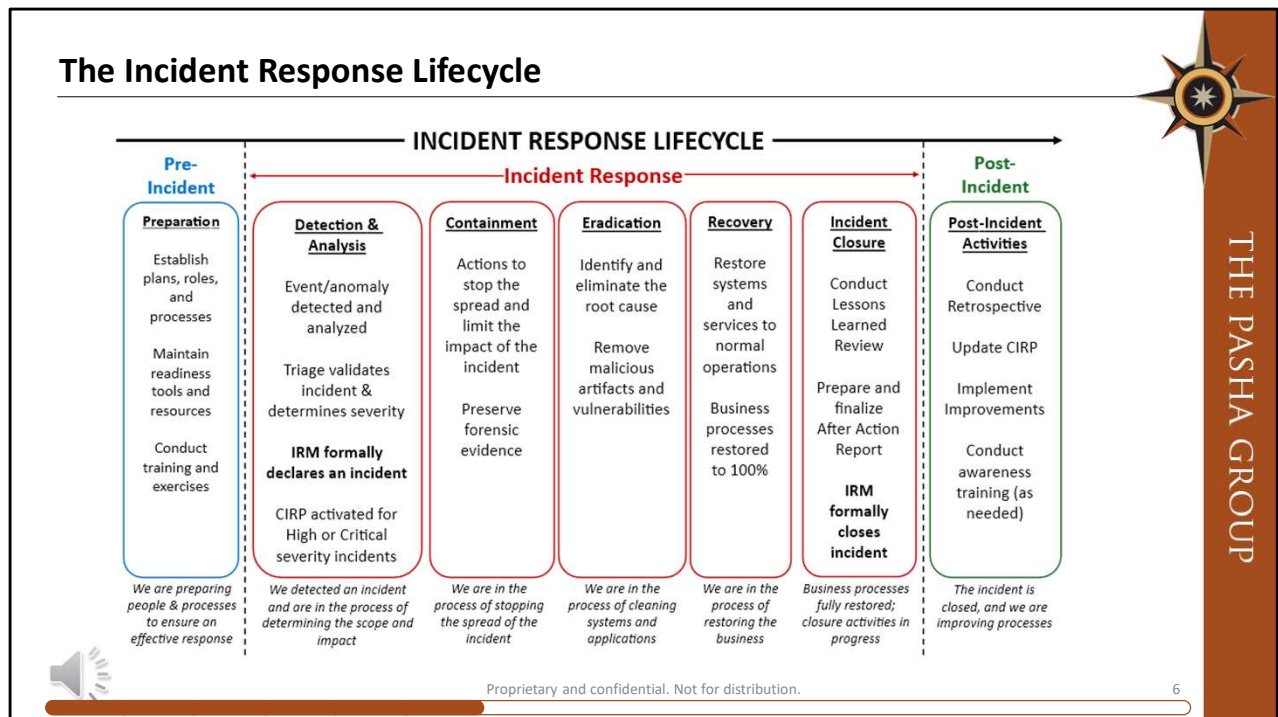
5

THE PASHA GROUP

Regulations define a cyber incident as “an occurrence that actually jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system, or actually jeopardizes, without lawful authority, an information system.”

That can include unauthorized system access, malware or ransomware, phishing emails where someone clicks a link, disruptions to OT systems, or insider misuse of access.

If something interferes with how systems should safely and reliably operate, it may be a cyber incident, and it should be treated seriously.



Cyber incidents follow a general lifecycle. Understanding these phases helps you recognize where your actions and information are most important.

Preparation is about readiness before anything happens. This includes having plans in place, knowing whom to contact, and understanding your role.

Detection & Analysis occur when something unusual is noticed. This is where early reporting, good observations, and accurate information are critical.

Containment focuses on limiting the impact of the incident. Systems may be isolated, access restricted, or operations adjusted to prevent further harm.

Eradication involves removing the root cause of the incident, such as malicious software or compromised accounts, so the threat does not return.

Recovery is the process of restoring systems and operations safely and verifying that everything is functioning as intended.

Incident Closure and **Post-Incident Activities** involve documenting what happened, capturing lessons learned, and updating plans, controls, and training to reduce future risk.

You don't need to memorize each phase, but you should understand where you fit in and when your actions or information are most important.

Your Role During a Cyber Incident

- Key Personnel support a safe and coordinated response

1

Recognize & Report

2

Support Assessment & Decision-Making

3

Support Containment & Recovery



Proprietary and confidential. Not for distribution.

7

THE PASHA GROUP

Key Personnel include a wide range of roles, from operational leaders to technical specialists. Some of you may be deeply technical experts, while others support operations, supervision, or decision-making.

As a result, your specific actions during a cyber incident may vary. Regardless of role, the shared objective is the same: support a safe and coordinated response.

In general, Key Personnel responsibilities fall into three areas: recognizing and reporting issues, supporting assessment and decision-making, and assisting with containment and recovery when directed. How you contribute within those areas will depend on your expertise, access, and assigned responsibilities.

Your Role During a Cyber Incident (continued)

Recognize & Report

- Watch for abnormal IT/OT behavior
- Report immediately
- Do not change systems unless directed or trained to do so

Support Assessment & Decisions

- Identify affected systems or operations
- Share accurate information with CySO

Support Containment & Recovery

- Follow directions to isolate systems
- Maintain communication
- Follow safety and response procedures



THE PASHA GROUP



Proprietary and confidential. Not for distribution.

8

First, **recognize and report**.

If you see abnormal IT or OT behavior, unexpected alarms, system slowdowns, or anything that just seems off, report it immediately using established reporting channels.

One important rule here: don't start changing system settings unless you're trained and directed to do so. Well-intentioned actions can sometimes erase evidence or make the situation harder to assess.

Once something is reported, Key Personnel often **help with assessment & decision-making**.

That means explaining which systems or operations might be affected, sharing accurate information with the CySO or leadership, and helping determine whether operations need to pause, slow down, or change for safety reasons.

Your operational knowledge is critical here. It helps leadership understand real-world impacts.

To **support containment and recovery**, you may be asked to help isolate systems, restrict access, or carry out specific actions.

The key expectations are clear communication, following directions, and sticking to established safety and response procedures. Cyber incidents can be stressful, but coordinated action prevents confusion and reduces risk.

The Cybersecurity Incident Response Plan

- The Cybersecurity Incident Response Plan (CIRP) is the organization's enterprise-wide plan for managing cyber incidents.
- Applies across facilities, vessels, and supporting business operations
- Defines roles, communication paths, and decision-making authority
- Establishes a Cyber Incident Response Team (CIRT)



THE PASHA GROUP



Proprietary and confidential. Not for distribution.

9

We've talked about what a cyber incident is and the kinds of actions Key Personnel may take during a response. To make sure those actions are coordinated and effective, the organization uses an enterprise-wide Cybersecurity Incident Response Plan, often called the CIRP.

The CIRP was developed in 2025 and applies across the organization, including facilities, vessels, and supporting business operations. It is the organization's playbook for managing cyber incidents in a consistent, coordinated way.

The CIRP defines how incidents are handled end-to-end. It establishes a Cyber Incident Response Team, or CIRT, which brings together technical experts, operational leaders, and support personnel during an incident.

The CIRP lays out who does what, how information flows, who makes decisions, and how actions are documented. Its purpose is to remove guesswork and ensure everyone is working toward the same objectives during a stressful situation.

Some people in this training, including certain contractors or newly assigned personnel, may not have seen the CIRP yet or may not have direct access to it. That is expected. You are not required to memorize the CIRP or carry a copy to fulfill your role as Key Personnel.

What matters is knowing that the CIRP exists and understanding that it governs how cyber incidents are handled.

Using the CIRP During an Incident

- During a cyber incident, the CIRP guides how the organization responds.
- Key Personnel should:
 - Report concerns and follow direction from the CySO or leadership
 - Use CIRP reporting, communication, and documentation protocols
 - Follow the CIRP for role-specific responsibilities, as assigned
 - Coordinate closely with the CySO and Incident Response Team (IRT)
- Not all Key Personnel will have direct access to the CIRP. In those cases, the expectation is to follow direction provided by the CySO or leadership.



Proprietary and confidential. Not for distribution.

10

THE PASHA GROUP

When a cyber incident occurs, the CIRP becomes the central reference for how the organization responds.

The CIRP guides the response from start to finish. It outlines how incidents are identified and escalated, how the Cyber Incident Response Team is activated, how decisions are coordinated, and how actions are documented and tracked throughout the event.

For technical roles, the CIRP provides structure for detection & analysis, containment, eradication, and recovery activities, as well as coordination with operations and leadership. For non-technical roles, it provides clear direction on reporting, communication, decision support, and operational coordination.

Your role is not to improvise or decide response steps on your own. Instead, you follow directions from leadership or the Cybersecurity Officer, use established reporting and communication channels, and support response actions that align with the CIRP.

This applies whether you are in a technical role or a non-technical role, and whether or not you personally have access to the CIRP. The plan ensures that technical teams, operations, leadership, and contractors are all operating from the same playbook.

Why Staying Current Matters

- Cyber threats evolve constantly; new vulnerabilities and attack techniques emerge daily.
- Advancements in artificial intelligence (AI) are enabling more sophisticated attacks, including automated exploitation, highly targeted phishing, and manipulation of OT system behavior.
- OT systems are increasingly targeted because of their operational and physical impact.
- Staying informed helps prevent incidents, supports early detection, and enables safer, more effective responses.
- Updated awareness strengthens compliance with USCG cybersecurity requirements and supports the CySO's ability to protect the organization.



Proprietary and confidential. Not for distribution.

11

THE PASHA GROUP

Up to this point, we've focused on how cyber incidents are handled and how roles are coordinated during a response. An equally important part of cybersecurity is what happens before an incident ever occurs.

Cyber threats change fast, and they're getting more complex.

Advances in artificial intelligence are enabling more convincing phishing, faster attacks, and more targeted exploitation of OT systems. That means what worked to prevent incidents last year may not be enough this year.

Staying current helps reduce risk, prevent incidents, and improve early detection when something does go wrong.

What to Stay Informed About

- New vulnerabilities (KEVs)
- Vendor security advisories
- Emerging attack tactics (phishing, credential theft, ransomware, OT threats)
- OT system risks and abnormal behavior
- Updates to policies, procedures, and access controls
- Lessons learned from incidents, exercises, and industry events



Proprietary and confidential. Not for distribution.

12

THE PASHA GROUP

As Key Personnel, staying informed means maintaining awareness of changes that could affect safety, security, or operations.

This includes awareness of new vulnerabilities, emerging attack techniques, risks affecting operational technology and industrial control systems, and updates to internal procedures or safeguards.

In practical terms, this means paying attention to changes that impact the systems you oversee, the vendors or tools you rely on, and the ways attackers are targeting similar facilities or vessels.

You are not expected to track everything or become a cybersecurity expert. The expectation is that you recognize when something new, unusual, or higher-risk could affect the systems or operations you're responsible for, and that you raise those concerns through the appropriate channels.

Approved Information Sources

- To stay current, Key Personnel should review:
 - Internal cybersecurity communications, including briefings, email newsletters, and security updates
 - Vendor/OEM advisories for hardware, software, and OT systems used on-site
 - USCG Marine Safety Information Bulletins (MSIBs) and cyber-related notices
 - Sector ISAC/ISAO bulletins relevant to maritime, energy, transportation, or OT environments
 - CISA alerts, ICS advisories, and the Known Exploited Vulnerabilities (KEV) catalog



Proprietary and confidential. Not for distribution.

13

THE PASHA GROUP

Now that we've talked about *what* to stay informed about, let's talk about *where* that information comes from.

To maintain awareness, the organization relies on approved information sources. These are trusted places used to understand which cyber threats actually matter to operations.

These sources include alerts and guidance from the Cybersecurity and Infrastructure Security Agency, information about Known Exploited Vulnerabilities (publicly identified weaknesses that attackers are actively using), sector information-sharing groups focused on maritime, transportation, or industrial systems, vendor or manufacturer security advisories, internal updates from the Cybersecurity Officer, and U.S. Coast Guard Marine Safety Information Bulletins.

How to Maintain Awareness

- Participate in internal briefings, training, drills, or exercises where threat information and response updates are shared
- Review updates regularly from approved sources, especially when new vulnerabilities or threats are reported
- Apply updated procedures or controls as directed by supervisors, the CySO, IT, or Cyber
- Communicate emerging concerns, suspicious activity, or potential impacts to the CySO promptly
- Engage in continuous learning, reviewing reference materials, and reinforcing knowledge through refresher training



Proprietary and confidential. Not for distribution.

14

THE PASHA GROUP

Because Key Personnel includes both technical and non-technical roles, responsibilities for monitoring and acting on this information vary.

For non-technical Key Personnel, the focus is not on technical detail, but operational impact. These sources help answer practical questions such as whether an issue could affect systems, safety, or operations, and whether awareness or action is required.

Non-technical Key Personnel are not expected to read technical advisories or monitor these sources independently. Instead, their role is to pay attention when summaries are shared internally, understand when an issue may have operational or safety impacts, ask questions when something is unclear, and follow direction when procedures or controls are updated.

For technical Key Personnel, monitoring these sources may be part of assigned responsibilities. In those roles, expectations may include reviewing advisories directly, assessing relevance to systems in use, supporting mitigation actions, and advising leadership or the Cybersecurity Officer on potential risks.

In summary, the Cybersecurity Officer and technical teams coordinate review and response activities. Key Personnel support that process by staying engaged, informed at the appropriate level for their role, and responsive when updates are communicated.

Key Takeaways

- Know your responsibilities before, during, and after a cyber incident
- Report concerns immediately and through the correct channels
- Stay informed about evolving cyber threats
- Support the CySO and help maintain safe, resilient operations



THE PASHA GROUP



Proprietary and confidential. Not for distribution.

15

To wrap up:

As Key Personnel, your role is defined by your responsibilities, access, and influence on operations. Know what's expected of you and where you fit in the organization's cybersecurity approach.

Report issues early. Timely reporting is one of the most effective ways to prevent a cyber issue from escalating into a larger incident.

Stay informed at the level appropriate for your role, whether that means understanding operational impacts or directly monitoring technical advisories.

Most importantly, remember that cybersecurity is not just an IT issue. It is an operational safety and security issue, and your actions before, during, and after an incident directly support safe, resilient, and compliant operations.

Questions & Follow-Up

- If you have any questions, please contact:
 - Justin Brown, Sr. Director of Cybersecurity, justin_brown@pashanet.com
 - Dan Limon, Cybersecurity Architect, dan_limon@pashanet.com



THE PASHA GROUP



Proprietary and confidential. Not for distribution.

16

If you have questions after completing this training, or if you are unsure how any of this applies to your role, please contact your designated point of contact.

Questions related to cybersecurity procedures, incident reporting, access requirements, or training applicability should be directed to the individual who will be designated as the Cybersecurity Officer, or their designated alternate.

Reaching out early with questions or concerns helps ensure issues are addressed appropriately and supports safe, compliant operations.